

# Streetrack Ubuntu 24.04 STIG Compliance Pipeline

## Standard Operating Procedure (SOP)

### 1. Purpose

The purpose of this SOP is to establish a standard, consistent, and repeatable process to secure Ubuntu 24.04 LTS servers. This procedure defines how to assess the server against the DISA Ubuntu 24.04 STIG benchmark, apply security remediations, validate system functionality, perform a verification assessment, and review the remaining findings before the server is approved for production.

### 2. Scope

This SOP applies to Streetrack Ubuntu 24.04 LTS servers that are being prepared for production use. It covers the full hardening workflow including baseline assessment, remediation, functionality validation, verification assessment, and review of residual findings. Enterprise services and controls such as PKI, smart-card authentication, centralized audit storage, or FIPS-enabled environments are not part of the project scope.

### 3. Roles and Responsibilities

| Role                                            | Responsibilities                                                                                                                   |
|-------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------|
| Information Security Manager                    | Reviews security objectives, assessment results, residual findings, and determines whether remaining risks are acceptable          |
| Linux/System Administrator                      | Runs and maintains the hardening pipeline, performs remediation and validation, and preserves evidence                             |
| External Security Auditor / Compliance Reviewer | Reviews benchmark evidence, assessment results, logs, and residual findings to verify the hardening process was properly completed |

### 4. Required Tools and Prerequisites

- Ubuntu 24.04 LTS target server with administrative access
- Tenable Nessus access with DISA Ubuntu 24.04 STIG audit content
- Credentialed SSH access from Nessus scanner to target server
- Ansible control node with connectivity to target server
- Python and Nessus API automation script
- Bash and standard Linux utilities for functionality validation
- GitHub repository for storing project files and evidence
- Protected SSH keys, Nessus API credentials, and other sensitive values

## **5. Procedure**

### **5.1 Prepare the Target and Management Path**

- Confirm the Ubuntu 24.04 LTS target server is reachable from the required systems
- Confirm SSH administrative access and privilege escalation are working
- Confirm Ansible control node can manage target
- Confirm Nessus credentialed scanning and API access are operational
- Protect credentials and do not store plaintext secrets in repository

### **5.2 Perform the Baseline Nessus Assessment**

- Run Nessus STIG compliance assessment against the target
- Use the Ubuntu 24.04 DISA STIG audit content
- Export and preserve the baseline report as project evidence
- Record baseline scan results and measure compliance percentage
- Use baseline as the reference point for all post-remediation comparison

### **5.3 Review Baseline Findings**

- Review baseline findings to identify weaknesses and limitations
- Do not assume every failed control can or should be remediated in the environment
- Identify controls that depend on unavailable enterprise infrastructure, platform capabilities or manual validation

### **5.4. Execute Ansible Remediation**

- Run the Ansible site playbook against the target server
- Apply the upstream UBUNTU24-STIG role for broad STIG remediation
- Apply the Streetrack custom streetrack\_stig role for project-specific config changes
- Preserve the Ansible execution output as evidence
- If implementation errors occur, correct only necessary configs to restore workflow and required functionality

### **5.5 Perform Functionality Validation**

- Run functionality\_test.sh script after remediation
- Confirm Ansible connectivity
- Confirm successful privilege escalation
- Confirm SSH service is active
- Confirm auditd is active
- Confirm network interfaces and routing remain available
- Confirm external network connectivity
- Confirm UFW status and administrative access remain allowed
- Preserve the functionality validation log as evidence

## **5.6 Perform Idempotency Validation**

- Rerun Ansible remediation workflow a second time
- Verify playbook completes without failed or unreachable hosts
- Document remaining changed tasks if not changed-free
- Treat idempotency run as supportive evidence

## **5.7 Perform the Verification Nessus Assessment**

- Run the same Nessus STIG assessment after remediation and functionality validation
- Export and preserve verification scan report
- Record verification results and measure compliance percentage
- Compare verification metrics against previous baseline assessment

## **5.8 Analyze Results**

- Calculate change in measured compliance
- Calculate reduction in failed controls
- Confirm that required system functions remain operational
- Review significant residual findings by cause or dependencies
- Identify any post-remediation regressions found by verification assessment

## **5.9 Review and Disposition Residual Findings**

- Document residual findings that require enterprise identity, PKI, smart-card, centralized logging, or other infrastructure not present in the project environment
- Document remaining unresolved configuration weaknesses
- Record any regression for future remediation or maintenance plan

## **5.10 Complete the Assessment Cycle**

- Confirm baseline, remediation, validation, and residual findings evidence are preserved
- Provide final results to appropriate stakeholders
- Consider workflow complete when remediation has been executed, functionality validated, verification completed, results analyzed, and residual findings reviewed

# **6. Acceptance Criteria**

The assessment cycle is considered successful when the following criteria are met:

- Verification assessment is at least 80% STIG compliant
- Failed STIG controls reduced by at least 70% from baseline results
- All required functionality validation tests pass
- Residual findings are reviewed and documented
- Administrative access, networking, and required services remain operational

## 7. Evidence to Retain

- Baseline Nessus STIG assessment report
- Ansible remediation log
- Ansible idempotency log
- Verification Nessus STIG assessment report
- Functionality validation log
- Residual Findings Summary
- Current version of this SOP
- Relevant playbooks, scripts, and configuration files stored in project repo

## 8. Maintenance and Reassessment

The pipeline should be reviewed on a regular basis to ensure the hardening process remains current and effective.

- Perform quarterly reassessments and functionality validation to identify drift or new weaknesses
- Perform annual review of Ansible roles, SOP, residual findings, and current DISA STIG
- Reassess the server after major Ubuntu updates and DISA STIG version changes
- Update remediation scripts, documentation, and findings as needed based on reassessment results

## 9. Current Project Reference Results

| Assessment   | Passed | Failed | Measured Compliance |
|--------------|--------|--------|---------------------|
| Baseline     | 56     | 127    | 30.6%               |
| Verification | 166    | 16     | 91.2%               |

*Observed improvement: Approximately 87.4% reduction with 111 fewer failed controls*

## 10. Procedure Summary

**Assess → Remediate → Validate → Verify → Review**